Durcir une machine Linux, et le prouver

Constant Segretain

Préparation

```
sudo id                              # doit contenir uid=0(root)
```

Créez les trois comptes du TP :

```
# Compte cible (victime des tests d'attaque, aucun privilège)
sudo useradd -m -s /bin/bash cible
echo 'cible:Cible-Labo-2026' | sudo chpasswd

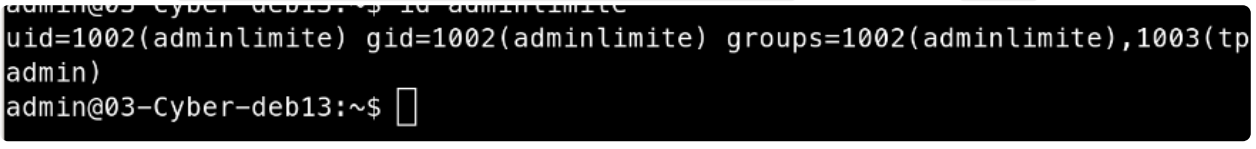
# Compte adminlimite (administration limitée, PAS dans le groupe sudo)
sudo useradd -m -s /bin/bash adminlimite
echo 'adminlimite:Admin-Labo-2026' | sudo chpasswd

# Groupe d'administration restreinte
sudo groupadd tpadmin
sudo usermod -aG tpadmin adminlimite
```

Preuve à relever :

```
id adminlimite
```

→ attendu : `groups=...(adminlimite),...(tpadmin)` — **pas** de `sudo` dans la liste.



Phase 0 — Audit initial

```
sudo apt update
sudo apt install -y lynis
sudo lynis audit system
```

Q0.1 & Q0.2 (Score et suggestions Lynis) : Mon score de départ (66) est plutôt bon, car Debian 13 est sécurisé par défaut.

Puis installez les outils du reste de la journée :

```
sudo apt install -y openssh-server fail2ban nftables auditd \
     apparmor-utils apparmor-profiles hydra nmap libpam-pwquality
```

Phase 1 — Comptes et privilèges

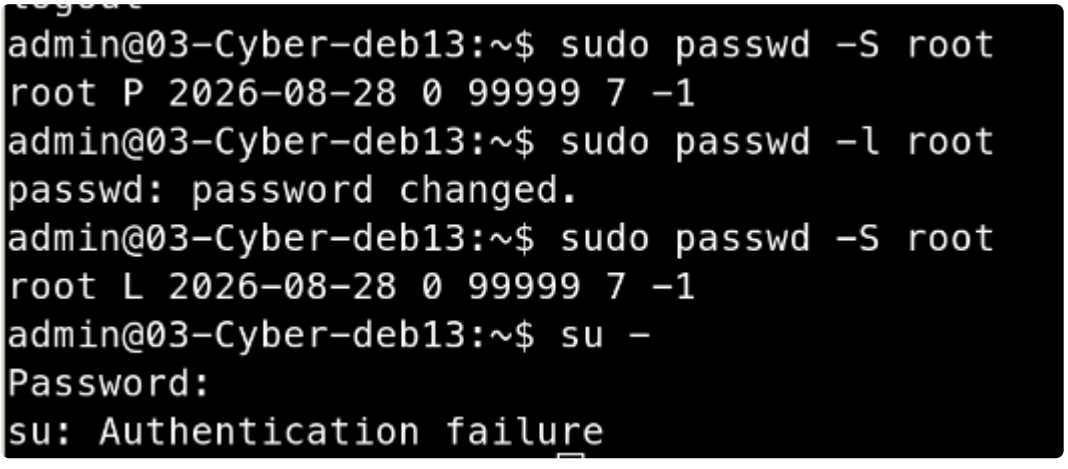
1.1 Verrouiller le mot de passe de root

```
sudo passwd -S root       # état avant
sudo passwd -l root       # verrouille
sudo passwd -S root       # état après → L (Locked)
```

Preuve (depuis un compte non-root) :

```
su - root
```

→ attendu : `su: Authentication failure`.



1.2 Politique de mots de passe (PAM + pwquality)

```
grep pwquality /etc/pam.d/common-password
```

```
password        requisite                       pam_pwquality.so retry=3
```

Éditez `/etc/security/pwquality.conf` :

```
minlen = 12
minclass = 3
maxrepeat = 3
```

Preuve — `cible` change **son propre** mot de passe (jamais `sudo passwd cible`) :

```
su - cible
passwd            # ancien mot de passe, puis essayez "azerty"
exit
```

→ attendu : `azerty` refusé.

```
cible@03-Cyber-deb13:~$ passwd
Changing password for cible.
Current password:
New password:
BAD PASSWORD: The password is shorter than 12 characters
```

1.3 Moindre privilège : sudo réellement restreint

```
sudo visudo -f /etc/sudoers.d/tp
```

Contenu exact :

```
%tpadmin ALL=(root) /usr/bin/systemctl --no-pager status ssh
%tpadmin ALL=(root) /usr/bin/systemctl restart ssh
%tpadmin ALL=(root) /usr/bin/journalctl --no-pager -u ssh
%tpadmin ALL=(root) /usr/sbin/aa-status
```

Preuve :

```
su - adminlimite
sudo -l                                          # liste EXACTEMENT
les 4 commandes
sudo /usr/bin/systemctl --no-pager status ssh    # AUTORISÉ
sudo /bin/bash                                   # INTERDIT
sudo systemctl restart cron                      # INTERDIT (argument
```

```
non autorisé)
exit
```

```
User adminlimite may run the following commands on 03-Cyber-deb13:
    (root) /usr/bin/systemctl --no-pager status ssh
    (root) /usr/bin/systemctl restart ssh
    (root) /usr/bin/journalctl --no-pager -u ssh
    (root) /usr/sbin/aa-status
```

```
adminlimite@03-Cyber-deb13:~$ sudo /usr/bin/systemctl --no-pager status ssh
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: e
nabled)
     Active: active (running) since Fri 2026-08-28 09:23:59 UTC; 2h 35min ag
o
```

```
adminlimite@03-Cyber-deb13:~$ sudo /bin/bash
Sorry, user adminlimite is not allowed to execute '/bin/bash' as root on 03-
Cyber-deb13.
```

```
adminlimite@03-Cyber-deb13:~$ sudo systemctl restart cron
Sorry, user adminlimite is not allowed to execute '/usr/bin/systemctl restar
t cron' as root on 03-Cyber-deb13.
```

Q1.1, Q1.2 & Q1.3 (Root et sudo) : On verrouille `root` sans le supprimer, car l'UID 0 est indispensable au fonctionnement du système Linux. L'exception pour `root` sur la complexité des mots de passe permet à l'admin d'intervenir en urgence. Enfin, pour `adminlimite`, on interdit les éditeurs (`vi`, `less`) dans `sudo` car ils permettent d'ouvrir un sous-shell (`!/bin/bash`) et de récupérer les droits `root` totaux (échappement).

```
Hardening index : 66 [#############        ]
Tests performed : 255
Plugins enabled : 1
```

Phase 2 — SSH et défense contre la force brute

2.1 Vérifier SSH

```
sudo systemctl enable --now ssh
sudo ss -tulpn | grep :22
```

2.2 fail2ban

Créez `/etc/fail2ban/jail.local` :

```
[DEFAULT]
ignoreself = false
ignoreip =
banaction = nftables-multiport

[sshd]
enabled  = true
backend  = systemd
maxretry = 3
bantime  = 600
findtime = 300
```

```
sudo systemctl restart fail2ban
sudo fail2ban-client status sshd
```

2.3 Force brute contre soi-même

```
{ echo cible; echo 1234; echo password; echo root; for i in $(seq 1
30); do echo "pass$i"; done; } > /tmp/wl.txt
hydra -l cible -P /tmp/wl.txt ssh://127.0.0.1 -t 4
```

Preuve du bannissement (trois preuves convergentes) :

```
sudo fail2ban-client status sshd
sudo nft list ruleset | grep -A4 f2b-table
sudo grep 'Ban ' /var/log/fail2ban.log | tail
```

ip 127.0.0.1 banni :

```
admin@03-Cyber-deb13:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     6
|  `- Journal matches:  _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 1
   |- Total banned:     1
   `- Banned IP list:   127.0.0.1
admin@03-Cyber-deb13:~$ sudo nft list ruleset | grep -A4 f2b-table
table inet f2b-table {
        set addr-set-sshd {
                type ipv4_addr
                elements = { 127.0.0.1 }
        }
```

```
admin@03-Cyber-deb13:~$ sudo grep 'Ban ' /var/log/fail2ban.log | tail
2026-08-28 12:14:56,850 fail2ban.actions        [74355]: NOTICE  [sshd] Ban
127.0.0.1
```

2.4 Lever le bannissement

```
sudo fail2ban-client set sshd unbanip 127.0.0.1
```

2.5 Passer en clé uniquement

```
mkdir -p ~/.ssh && chmod 700 ~/.ssh
ssh-keygen -t ed25519 -f ~/.ssh/id_tp -N ""
cat ~/.ssh/id_tp.pub >> ~/.ssh/authorized_keys
chmod 600 ~/.ssh/authorized_keys
```

Dans `/etc/ssh/sshd_config` : `PermitRootLogin no` et `PasswordAuthentication no`. **Ne fermez pas votre session.**

```
sudo sshd -t && sudo systemctl reload ssh
sudo sshd -T | grep -Ei
'^(permitrootlogin|passwordauthentication|pubkeyauthentication)'
```

→ attendu : `permitrootlogin no`, `passwordauthentication no`, `pubkeyauthentication yes`.

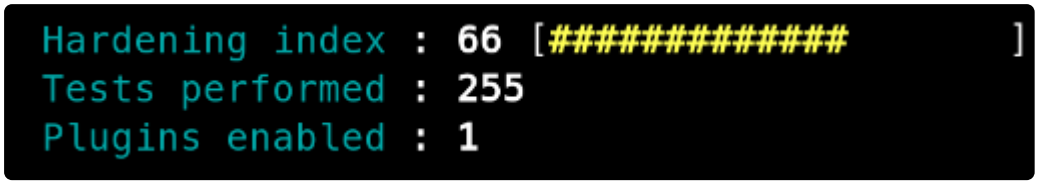
```
permitrootlogin no
pubkeyauthentication yes
passwordauthentication no
```

Puis, **dans une nouvelle session** (l'ancienne reste ouverte en secours) :

```
ssh -i ~/.ssh/id_tp -o StrictHostKeyChecking=accept-new 127.0.0.1
whoami   # OK
ssh -o PreferredAuthentications=password 127.0.0.1
# refusé
```



Q2.1, Q2.2 & Q2.3 (SSH et fail2ban) : La clé SSH empêche le vol de mot de passe, tandis que `fail2ban` empêche le déni de service (force brute). Même sans mot de passe, `fail2ban` est vital pour bloquer un attaquant qui inonde le réseau. Pour le prouver, on utilise `sshd -T` qui montre la configuration *réellement active en mémoire*, contrairement à `sshd -t` qui ne vérifie qu'un simple fichier texte.



Phase 3 — Pare-feu

3.1 Surface avant

```
sudo ss -tulpn
nmap 127.0.0.1
```



3.2 Politique de refus par défaut

Écrivez `/etc/nftables.conf` :

```
#!/usr/sbin/nft -f
flush ruleset
table inet filter {
```

```
    chain input {
        type filter hook input priority 0; policy drop;
        iif "lo" accept
        ct state established,related accept
        ct state invalid drop
        ip protocol icmp icmp type { echo-request, echo-reply,
destination-unreachable, time-exceeded } accept
        ip6 nexthdr icmpv6 icmpv6 type { echo-request, echo-reply,
destination-unreachable, packet-too-big, time-exceeded, nd-neighbor-
solicit, nd-neighbor-advert, nd-router-solicit, nd-router-advert }
accept
        tcp dport 22 accept
    }
    chain forward { type filter hook forward priority 0; policy drop;
}
    chain output  { type filter hook output  priority 0; policy
accept; }
}
```

```
sudo nft -c -f /etc/nftables.conf     # valide SANS charger
sudo systemctl enable --now nftables
sudo nft list ruleset
```

```
admin@03-Cyber-deb13:~$ sudo nft list ruleset
table inet filter {
       chain input {
               type filter hook input priority filter; policy drop;
               iif "lo" accept
               ct state established,related accept
               ct state invalid drop
               ip protocol icmp icmp type { echo-reply, destination-unreachable, echo
```

3.3 Rétablir fail2ban (le `flush ruleset` a supprimé sa table)

```
sudo systemctl restart fail2ban
sudo nft list ruleset | grep f2b-table
```

```
admin@03-Cyber-deb13:~$ sudo nft list ruleset | grep f2b-table
table inet f2b-table {
```

Preuve réseau — depuis une seconde machine (binôme)

Un scan sur `127.0.0.1` passe par `lo` et ne prouve rien sur le filtrage réseau réel.

```
# depuis VM2 :
```

```
nmap <IP-de-VM1>          # attendu : 22 ouvert, le reste filtered
```

```
admin@03-Cyber-deb13-01:~$ sudo nmap 192.168.122.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-28 13:56 UTC
Nmap scan report for 192.168.122.40
Host is up (0.00061s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE
22/tcp open  ssh
MAC Address: 52:54:00:BE:5F:14 (QEMU virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 17.44 seconds
```

Démonstration open / closed / filtered :

```
# sur VM1
python3 -m http.server 8080 &
sudo nft add rule inet filter input tcp dport 8080 accept
# depuis VM2
nmap -p 8080 <IP-de-VM1>          # open
# sur VM1
kill %1
# depuis VM2
nmap -p 8080 <IP-de-VM1>          # closed
# sur VM1
sudo nft delete rule inet filter input handle $(sudo nft -a list chain
inet filter input | awk '/tcp dport 8080/{print $NF}')
# depuis VM2
nmap -p 8080 <IP-de-VM1>          # filtered
```

```
admin@03-Cyber-deb13-01:~$ sudo nmap -p 8080 192.168.122.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-28 13:58 UTC
Nmap scan report for 192.168.122.40
Host is up (0.00056s latency).

PORT     STATE SERVICE
8080/tcp open  http-proxy
MAC Address: 52:54:00:BE:5F:14 (QEMU virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.20 seconds
```

```
admin@03-Cyber-deb13-01:~$ nmap -p 8080 192.168.122.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-28 14:01 UTC
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.06 seconds
```

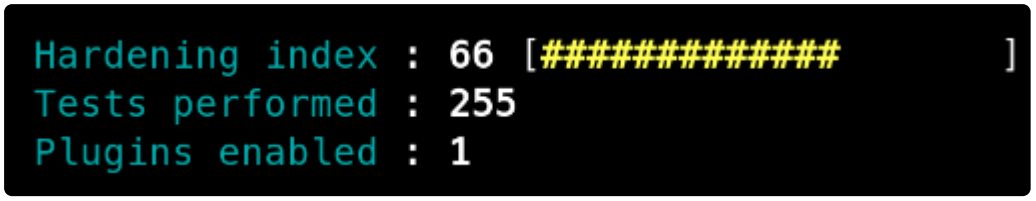
Bien en "filtered" :

```
admin@03-Cyber-deb13-01:~$ sudo nmap -p 8080 192.168.122.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-28 14:07 UTC
Nmap scan report for 192.168.122.40
Host is up (0.00051s latency).

PORT     STATE    SERVICE
8080/tcp filtered http-proxy
MAC Address: 52:54:00:BE:5F:14 (QEMU virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.40 seconds
```

Q3.1, Q3.2 & Q3.3 (Règles et Nmap) : Un port `closed` (fermé) signifie qu'il n'y a pas de service derrière, tandis que `filtered` prouve l'action du pare-feu (le paquet est bloqué). Avant d'activer le blocage par défaut (`policy drop`), il faut impérativement autoriser la boucle locale (`lo`) et le trafic établi (`established`), sinon la session SSH saute. Un pare-feu dépend toujours du métier (ex: un serveur Web doit ouvrir 80/443).



lynis ne monte pas la notes !?

Phase 4 — Surface d'attaque et noyau

4.1 Réduire la surface d'écoute

```
sudo ss -tulpn                          # 1. repérer un port + PID
ps -p <PID> -o comm=                    # 2. quel programme ?
systemctl status <service> --no-pager   # 3. quel service, à quoi sert-il ?
```

Exemple typique (exim4 sur `127.0.0.1:25`) :

```
sudo systemctl disable --now exim4
```

⚠️ **Ne touchez jamais** à `ssh`, au réseau (`systemd-networkd`, `NetworkManager`), à `systemd-journald`, `dbus`, ni aux unités `systemd-*`. En cas de doute : on ne désactive pas.

Preuve :

```
sudo ss -tulpn | grep :25
nmap 127.0.0.1
```



4.2 Paramètres noyau

Créez `/etc/sysctl.d/99-durcissement.conf` :

```
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.log_martians = 1
net.ipv4.tcp_syncookies = 1
```

```
sudo sysctl --system
sudo sysctl net.ipv4.conf.all.rp_filter
net.ipv4.conf.all.accept_redirects
```

```
* Applying /usr/lib/sysctl.d/10-coredump-debian.conf ...
* Applying /usr/lib/sysctl.d/50-default.conf ...
* Applying /usr/lib/sysctl.d/50-pid-max.conf ...
* Applying /etc/sysctl.d/99-durcissement.conf ...
kernel.core_pattern = core
kernel.sysrq = 0x01b6
kernel.core_uses_pid = 1
net.ipv4.conf.default.rp_filter = 2
net.ipv4.conf.ens3.rp_filter = 2
net.ipv4.conf.lo.rp_filter = 2
net.ipv4.conf.default.accept_source_route = 0
net.ipv4.conf.ens3.accept_source_route = 0
net.ipv4.conf.lo.accept_source_route = 0
net.ipv4.ping_group_range = 0 2147483647
net.core.default_qdisc = fq_codel
fs.protected_hardlinks = 1
fs.protected_symlinks = 1
fs.protected_regular = 2
fs.protected_fifos = 1
vm.max_map_count = 1048576
kernel.pid_max = 4194304
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.log_martians = 1
net.ipv4.tcp_syncookies = 1
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.all.accept_redirects = 0
```

Q4.1, Q4.2 & Q4.3 (Services et sysctl) :
Désactiver un service (`exim4`) réduit notre surface d'attaque réseau. Côté noyau, écrire dans un fichier `sysctl.conf` ne sert à rien tant qu'on ne le charge pas en mémoire. Attention, un réglage réseau strict (comme `rp_filter=1`) sécurise, mais peut casser le réseau légitime en production (comme les connexions VPN).

Phase 5 — AppArmor

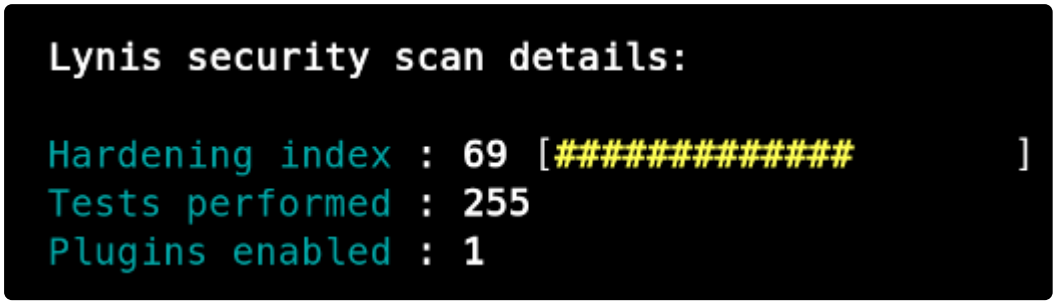
```
sudo cp /usr/bin/cat /usr/local/bin/tpcat
sudo tee /etc/apparmor.d/usr.local.bin.tpcat > /dev/null <<'EOF'
#include <tunables/global>
/usr/local/bin/tpcat {
  #include <abstractions/base>
  /usr/local/bin/tpcat mr,
```

```
  /etc/hostname r,
}
EOF
sudo apparmor_parser -r /etc/apparmor.d/usr.local.bin.tpcat
sudo aa-enforce /usr/local/bin/tpcat
sudo aa-status | grep tpcat
```

Preuve DAC vs MAC :

```
sudo /usr/local/bin/tpcat /etc/hostname   # AUTORISÉ
sudo /usr/local/bin/tpcat /etc/shadow     # REFUSÉ malgré root
sudo ausearch -m AVC -ts recent | tail    # ligne apparmor="DENIED"
... name="/etc/shadow"
```

Questions du CR (Q5.1, Q5.2) + **relancez Lynis** → notez le **point 4**.
après avoir redemarré la debian : 66 -> 69 :



Q5.1 & Q5.2 (MAC vs DAC) :
Les permissions classiques (DAC) obéissent à `root`, mais le modèle MAC (AppArmor) confine le processus lui-même et bloque l'action, même lancée par `root`. On teste toujours un profil en mode `complain` (journalisation) pour ajuster les droits avant de passer en `enforce` (blocage) pour éviter de casser le système.

Phase 6 — Journalisation et audit

6.1 Journal persistant

```
ls -ld /var/log/journal 2>/dev/null && echo "persistant" || echo
"volatile"
journalctl --list-boots
```

Si volatile :

```
sudo mkdir -p /var/log/journal
sudo systemctl restart systemd-journald
```

6.2 Règle d'audit persistante

```
echo '-w /etc/shadow -p wra -k acces_shadow' | sudo tee
/etc/audit/rules.d/durcissement.rules
sudo augenrules --load
sudo auditctl -l
```

Preuve :

```
sudo cat /etc/shadow > /dev/null
sudo ausearch -k acces_shadow | tail
```

```
admin@03-Cyber-deb13:~$ sudo auditctl -l
-w /etc/shadow -p rwa -k acces_shadow
```

```
admin@03-Cyber-deb13:~$ sudo ausearch -k acces_shadow | tail
type=PROCTITLE msg=audit(1787938285.628:322): proctitle=2F7573
85F63686B7077640061646D696E0063686B657870697279
type=PATH msg=audit(1787938285.628:322): item=0 name="/etc/sha
e:01 mode=0100640 ouid=0 ogid=42 rdev=00:00 nametype=NORMAL ca
e=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1787938285.628:322): cwd="/home/admin"
type=SYSCALL msg=audit(1787938285.628:322): arch=c000003e sysc
xit=3 a0=ffffff9c a1=7f07b7620da6 a2=80000 a3=0 items=1 ppid=3
000 uid=0 gid=1000 euid=0 suid=0 fsuid=0 egid=42 sgid=42 fsgid
mm="unix_chkpwd" exe="/usr/sbin/unix_chkpwd" subj=unix-chkpwd
```

`auditctl -l` (règle chargée) + la sortie `ausearch` retrouvant l'accès à `/etc/shadow`.

Q6.1 & Q6.2 (L'audit) : L'audit trace toutes les actions critiques sur la machine (qui a lu `/etc/shadow`, quand, comment). Un attaquant voudra effacer ces journaux locaux pour cacher ses traces, c'est pourquoi il faut les centraliser sur une autre machine inaccessible pour l'attaquant.

Phase 7 — Preuve de persistance : le redémarrage

```
logger "PREUVE-PERSISTANCE-TP-$(id -un)"
sudo reboot
```

Reconnectez-vous **avec votre clé** (le mot de passe est désactivé).

Table de survie à remplir après redémarrage :

Contrôle	Commande	Attendu
Journal persistant	`journalctl -b -1 | grep PREUVE-PERSISTANCE-TP`	marque retrouvée
Pare-feu	`sudo nft list ruleset | grep 'policy drop'`	politique chargée
SSH par clé	`sudo sshd -T | grep -Ei 'passwordauthentication|permitrootlogin'`	`no` / `no`
fail2ban	`sudo fail2ban-client status sshd`	jail active
AppArmor	`sudo aa-status | grep tpcat`	enforce
Règle auditd	`sudo auditctl -l`	`acces_shadow` présente
Service désactivé	`systemctl is-enabled <service>`	`disabled`

Journal persistant :

```
admin@03-Cyber-deb13:~$ journalctl -b -1 | grep PREUVE-PERSISTANCE-TP
Aug 28 17:35:18 03-Cyber-deb13 admin[35296]: PREUVE-PERSISTANCE-TP-admin
```

Pare-feu :

```
admin@03-Cyber-deb13:~$ sudo nft list ruleset | grep 'policy drop'
                type filter hook input priority filter; policy drop;
                type filter hook forward priority filter; policy drop;
```

clé SSH :

```
admin@03-Cyber-deb13:~$ sudo sshd -T | grep -Ei 'passwordauthentication|per
mitrootlogin'

permitrootlogin no
passwordauthentication no
```

fail2ban :

```
admin@03-Cyber-deb13:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     0
|  `- Journal matches:  _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `- Banned IP list:
```

AppArmor :

```
admin@03-Cyber-deb13:~$ sudo aa-status | grep tpcat
   /usr/local/bin/tpcat
```

Règle auditd:

```
admin@03-Cyber-deb13:~$ sudo auditctl -l
-w /etc/shadow -p rwa -k acces_shadow
```

Q7.1 & Q7.2 (Reboot) :
Retrouver les traces dans les journaux ou la règle `auditd` après un redémarrage prouve que la configuration a bien été inscrite sur le disque dur (elle est persistante), et pas seulement chargée en mémoire RAM (qui se vide à chaque redémarrage).

Bilan final

```
sudo lynis audit system
```

```
Hardening index : 69 [#############        ]
```

ligne `Hardening index` finale.

- **Q8.1, Q8.2 & Q8.3 (Score final et écarts) :** Mon score a progressé à 69. Cependant, un score Lynis n'est qu'un indicateur technique : on ne compare pas un serveur web public avec un stockage isolé.
- **Écarts résiduels (risques assumés) :** Je n'ai pas mis d'antivirus ClamAV, trop lourd pour une VM
